Departamento de Lenguajes y Sistemas Informáticos

E.T.S. Ingeniería Informática. Universidad de Sevilla

Avda Reina Mercedes s/n. 41012 Sevilla

E-mail lsi@lsi.us.es Web www.lsi.us.es

SEGURIDAD EN SISTEMAS INFORMÁTICOS Y EN INTERNET

Fecha: 20 de septiembre de 2026

Security Team X – Grupo 3

Auditor de seguridad: Kleber Leonardo de Carvalho, Tommaso Saccenti y Luigui Juan Guillermo

Para: Dirección de Seguridad

Clasificación del documento: confidencial / uso interno

INFORME DE AUDITORÍA DE CIBERSEGURIDAD

1. Resumen Ejecutivo y Estado de la Amenaza

Severidad Crítica (Estimación CVSS 8.8 - Exposición de Credenciales y Hashing Inadecuado).

Contexto: La base de datos de control de accesos se encuentra expuesta, lo que obliga a accionar de inmediato el protocolo de Assume Breach. El algoritmo de hashing utilizado (SHA-256 codificado en Base64 con un tamaño de 32 bytes) es excesivamente rápido e inadecuado para el almacenamiento de contraseñas, permitiendo que las GPUs modernas calculen miles de millones de hashes por segundo.

Factor Humano: El vector de ataque se agrava catastróficamente por la ingeniería social involuntaria. Los comentarios dejados por los usuarios funcionan como un fuzzing mental invertido, destruyendo la entropía de cualquier contraseña y permitiendo a un atacante dirigir perfectamente la explotación.

2. Auditoría de Código, Análisis Forense y Conformidad

El análisis sintáctico basado en las pistas de los usuarios y en los vectores recuperados permitió la reconstrucción de los ataques y la determinación exacta de las violaciones de la Política de Seguridad, sin necesidad de gastar poder computacional excesivo en la fuerza bruta ciega de los hashes.

CONFIDENTIAL

2.1 Matriz de Análisis e Incumplimiento de Credenciales

Basado en el proceso de auditoría y recuperación técnica realizado en el anexo, a continuación se presenta la lista consolidada de las contraseñas que fueron recuperadas y expuestas durante el análisis:

Lista de credenciales recuperadas

1. Luis Toreman Gerto
    - **Contraseña: procras********

      Errores / Incumplimientos:

      Incumple la Regla 2b (ausencia total de caracteres numéricos).

      Incumple la Regla 2c (ausencia total de símbolos).

      (Aunque tiene una longitud adecuada de 13 caracteres y solo letras minúsculas, carece por completo de números y símbolos).
2. Ana Pearse Sanz
    - **Contraseña: 12345******

      Errores / Incumplimientos:

      Incumple la Regla 2a (ausencia total de letras, tanto mayúsculas como minúsculas).

      (A pesar de cumplir sintácticamente con el uso de números y un símbolo ., falla por completo en el concepto de seguridad al basarse en una secuencia numérica predecible, careciendo de la complejidad alfabética exigida).
3. Pedro Marteis Poncio
    - **Contraseña: 2902****

      Errores / Incumplimientos:

      Incumple la Regla 2a (ausencia total de letras).

      Incumple la Regla 2c (ausencia total de símbolos).

      (Se compone exclusivamente de un patrón numérico puro correspondiente a una fecha de nacimiento, vulnerando los requisitos de diversidad de caracteres).
4. Arturo Ruiz Gasca
    - **Contraseña: ruiz****arturo******

CONFIDENTIAL

Errores / Incumplimientos:

Incumple la Regla 2b (ausencia total de caracteres numéricos).

(A pesar de cumplir con una longitud robusta, tener letras y el símbolo requerido *, carece por completo de dígitos numéricos del 0 al 9. Este caso demuestra cómo las políticas estáticas tradicionales fallan ante ataques orientados por OSINT, ya que la contraseña se basaba en los datos personales del propio usuario).

(Nota: Las contraseñas originales obtenidas y las capturas detalladas de las sesiones de auditoría se encuentran archivadas en el Anexo Técnico de este documento).

3. Corrección en Capas y Plan de Acción (Arquitectura y Negocio)

La dependencia exclusiva de reglas estáticas (complejidad forzada) y de defensas puramente tecnológicas ignora la falla en el "cortafuegos humano". La remediación exige un enfoque estructurado en tres frentes:

3.1. Acciones Inmediatas (Hotfix y Respuesta a Incidentes)

Invalidación de Sesiones: Invalidación inmediata de todos los tokens de sesión activos en el servidor.

Restablecimiento Forzado (Password Reset): Imposición de cambio obligatorio de contraseña en el próximo inicio de sesión para todos los usuarios, exigiendo validación de identidad por segundo factor (correo electrónico o SMS).

3.2. Soluciones Técnicas (TI)

Modernización Criptográfica: Sustituir SHA-256 por funciones de derivación de claves exigentes en memoria (memory-hard), como Argon2id o bcrypt. Para prevenir Timing Attacks en verificaciones manuales, se deben utilizar siempre funciones de comparación de tiempo constante (crypto.timingSafeEqual).

Validación por Entropía (zxcvbn): Sustituir la validación puramente basada en expresiones regulares (Regex) por bibliotecas de cálculo de entropía real (ej. zxcvbn), que rechazan de forma autónoma palabras de diccionario, datos biográficos del usuario (nombres, fechas) y secuencias comunes, independientemente de que tengan símbolos o números.

CONFIDENTIAL

Bloqueo de Credenciales Comprometidas: Integrar filtros automáticos en el Sistema de Gestión de Identidades (ej. Active Directory / IAM) para impedir el uso de contraseñas débiles o presentes en bases de datos de filtraciones conocidas.

Implementación Obligatoria de MFA: Despliegue obligatorio de Autenticación Multifactor (TOTP o llaves de hardware FIDO2). El acceso a áreas críticas debe validar estrictamente el token criptográfico en el servidor (retornando 401 Unauthorized por ausencia de token y 403 Forbidden por privilegios insuficientes).

3.3. Soluciones Organizativas y de Negocio

Eliminación de Puntos de Inyección de Datos Sensibles: El campo de "Comentarios de la Contraseña" en la base de datos constituye un fallo arquitectural grave y debe eliminarse de forma permanente (drop de la columna).

Adopción de Gestores de Contraseñas Corporativos: Proveer e incentivar el uso de un gestor de credenciales homologado por la empresa, permitiendo a los colaboradores generar claves robustas, aleatorias y exclusivas.

Concienciación y Formación Continua (Security Awareness): Realizar talleres prácticos enfocados en ingeniería social, alertando a los colaboradores sobre el peligro de reutilizar datos personales (nombres, fechas de nacimiento de familiares) en credenciales corporativas.

Auditorías Periódicas Automatizadas: Establecer revisiones trimestrales/semestrales de cumplimiento de contraseñas y pruebas de intrusión recurrentes para detectar desviaciones antes de que sean explotadas por agentes maliciosos.

CONFIDENTIAL

ANEXO TÉCNICO: PROCESO DE RECUPERACIÓN DE CREDENCIALES Y ANÁLISIS FORENSE

En este anexo se detallan los procedimientos técnicos, comandos ejecutados y resultados obtenidos durante el proceso de auditoría y descifrado de credenciales mediante la herramienta Hashcat, considerando la estructura de almacenamiento basada en hashes SHA-256 con salt en Base64.

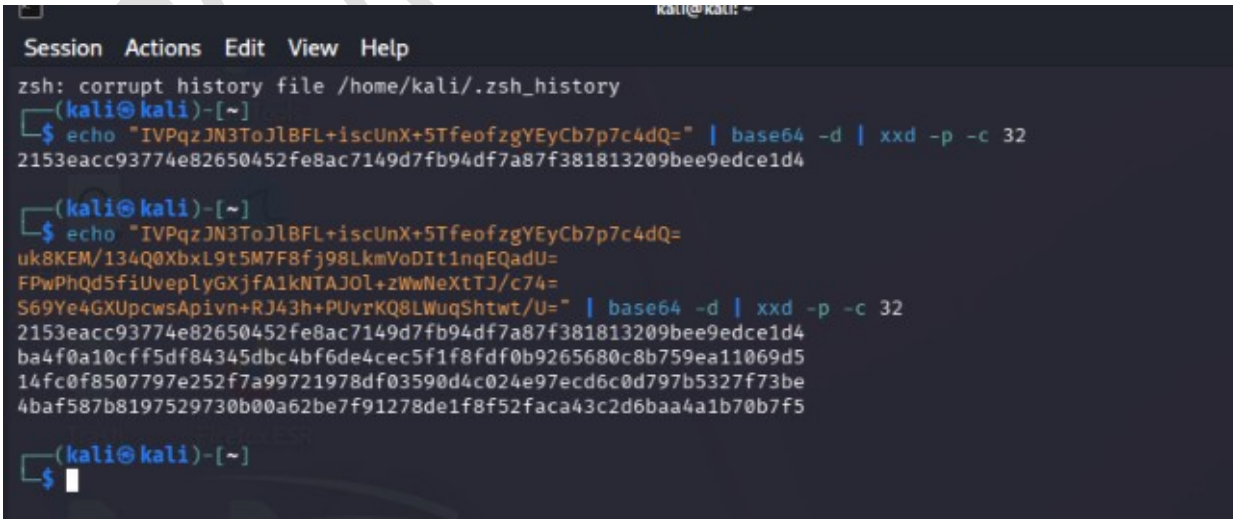
1. Preparación y Conversión de Hashes (Base64 a Hexadecimal)

Las credenciales extraídas de la base de data se encontraban codificadas en Base64 (tadenas de 44 caracteres que representan 32 bytes de hash bruto). Para su procesamiento en Hashcat, se convirtieron a formato hexadecimal mediante flujos de comandos Linux (base64 y xxd):

```
echo "IVPqzJN3ToJlBFL+iscUnX+5TfeofzgYEyCb7p7c4dQ=
      uk8KEM/134Q0XbxL9t5M7F8fj98LkmVoDIt1nqEQadU=
      FPwPhQd5fiUveplyGXjfA1kNTAJOl+zWwNeXtTJ/c74=
      S69Ye4GXUpcwsApivn+RJ43h+PUvrKQ8LWuqShtwt/U=" | base64 -d | xxd -p -c 32
```

Hashes brutos obtenidos (con sus respectivos salts numéricos extraídos del sistema):

- **2153eacc93774ce2480452fe8ac7149d7fb94df7a87f381813209bee9edce1d4:40**
- **ba4f0a10cff5df84345dbc4bf6de4cec5f1f8fdf0b9265680c8b759ea11069d5:51**
- **14fc0f8507797e252f7a99721978df03590d4c024e23ecd6c0d797b5327f73be:18**
- **4baf587b8197529730b00a62be7f91278de1f8f52faca43c2d6baa4a1b70b7f5:31**



CONFIDENTIAL

Nota sobre Modes de Hashcat: Como se desconoce inicialmente si el sistema aplica el salt antes o después de la contraseña, se validaron los modos 1410 (sha256($pass.$salt)) y 1420 (sha256($salt.$pass)).

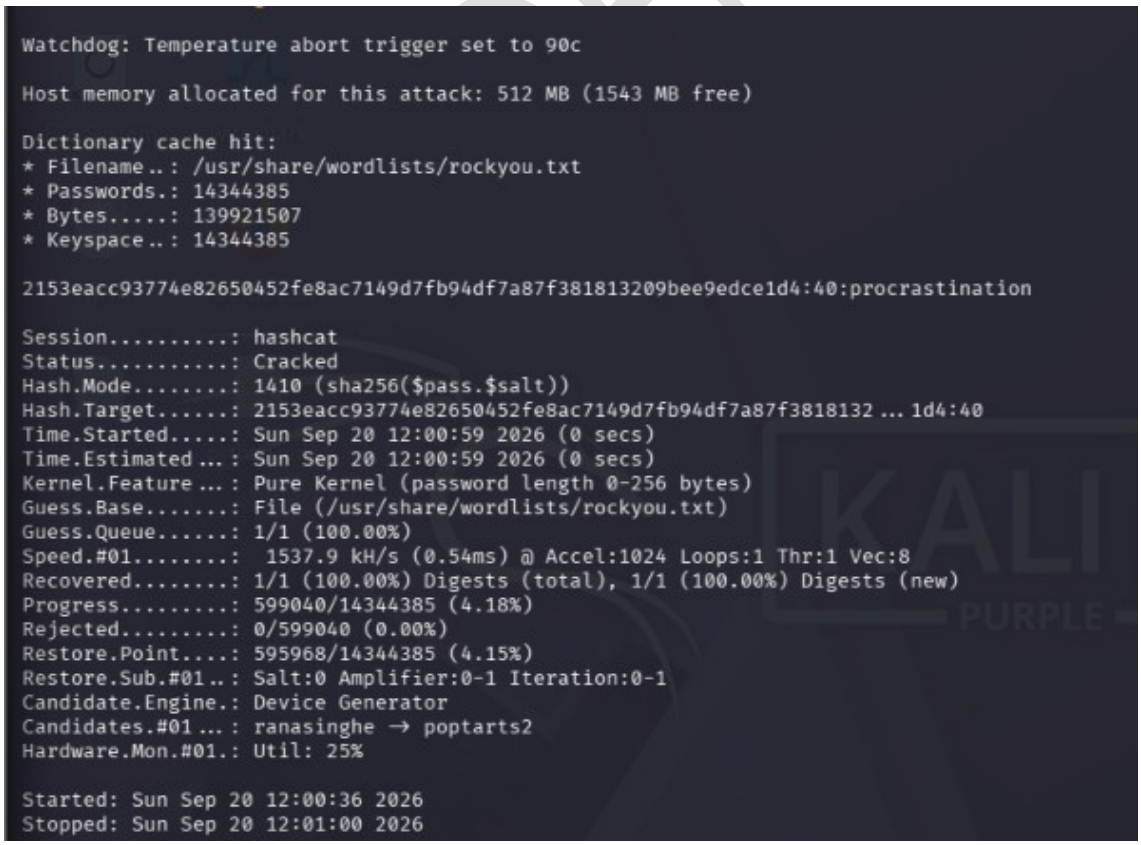
2. Auditoría por Usuario y Vectores de Explotación

A. Luis Toreman Gerto

- Pista analizada: Palabra rara de la lengua inglesa.
- Técnica: Ataque de Diccionario puro (-a 0) empleando la wordlist estándar rockyou.txt.
- Comando ejecutado:

hashcat -m 1410 -a 0 hash_luis.txt /usr/share/wordlists/rockyou.txt

- Resultado del descifrado (--show): 2153eacc93774e82650452fe8ac7149d7fb94df7a87f381813209bee9edce1d4:40:procrastination
    - **Contraseña encontrada: procrastination**



B. Ana Pearse Sanz

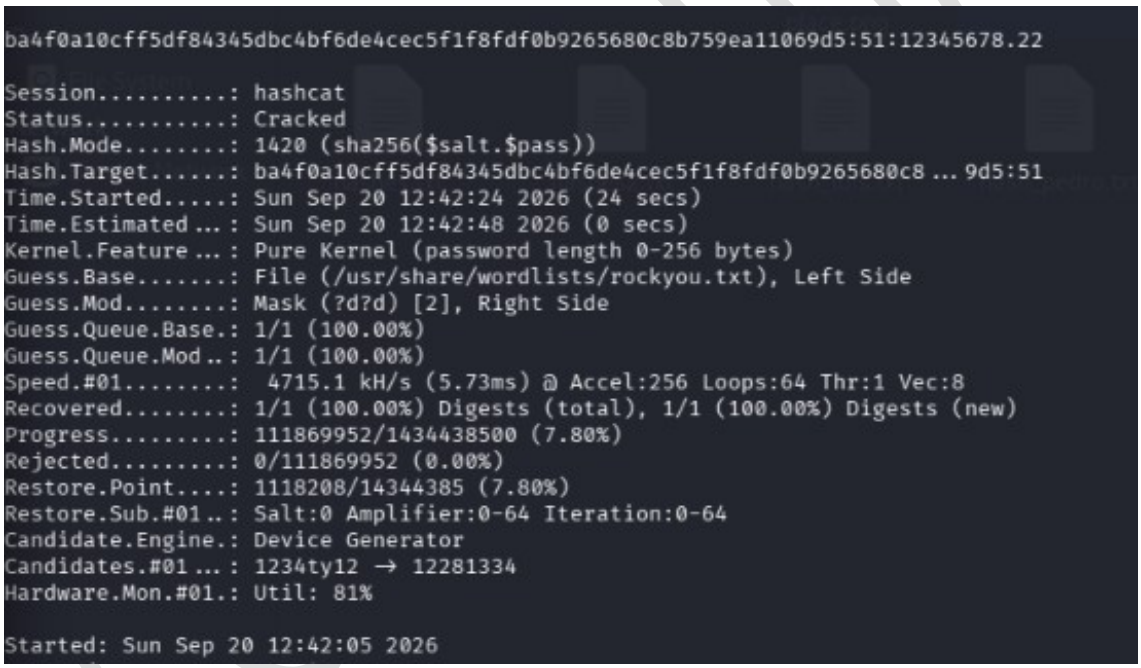
- Pista analizada: Contraseña común seguida de un punto y dos números.
- Técnica: Ataque Híbrido Diccionario + Máscara (-a 6), combinando el top de contraseñas comunes con la máscara de sufijo ?d?d.
- Comando ejecutado:

hashcat -m 1420 -a 6 hash_ana.txt /usr/share/wordlists/rockyou.txt ?d?d

- Resultado del descifrado:

  ba4f0a10cff5df84345dbc4bf6de4cec5f1f8fdf0b9265680c8b759ea11069d5:51:12345678.22

  - **Contraseña encontrada: 12345678.22**
  - **Métricas de ejecución: Tiempo total de 24 segundos a una velocidad promedio de ~4,715 kH/s.**

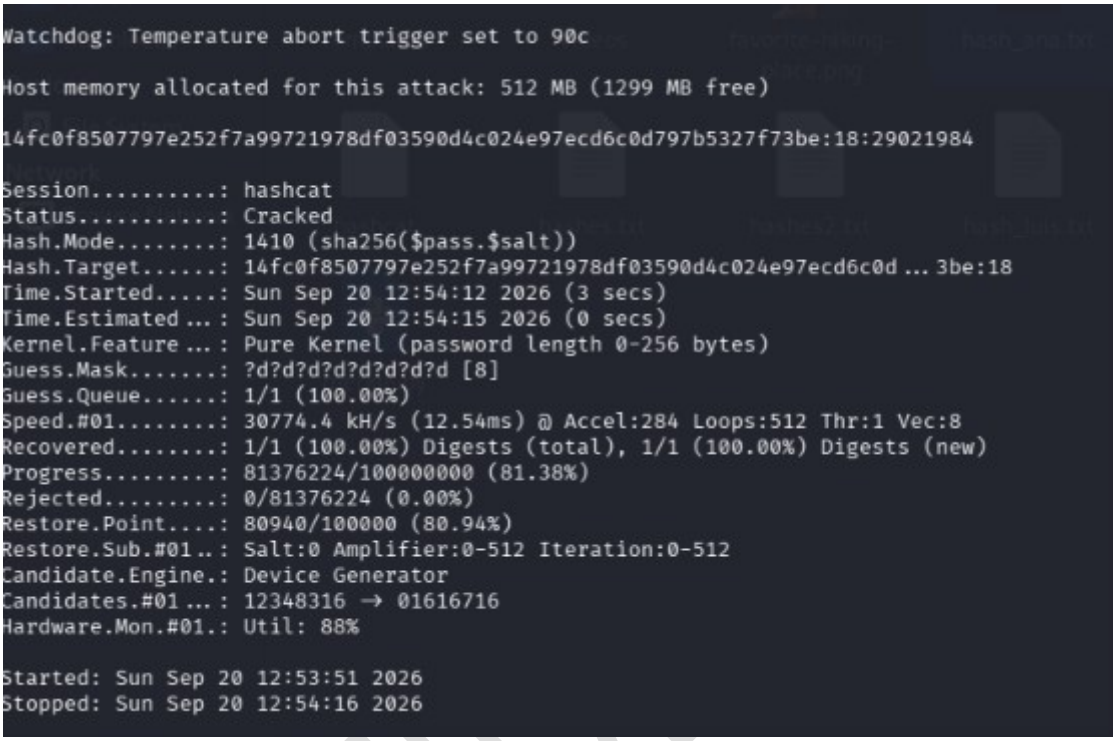


C. Pedro Marteis Poncio

- Pista analizada: Fecha de nacimiento de uno de sus hijos (formato numérico de 8 dígitos).
- Técnica: Ataque de Fuerza Bruta con Máscara de 8 dígitos (-a 3 con patrón ?d?d?d?d?d?d?d?d).
- Comando ejecutado:

hashcat -m 1420 -a 3 hash_pedro.txt ?d?d?d?d?d?d?d?d

- Resultado del descifrado:
  14fc0f8507797e252f7a99721978df03590d4c024e97ecd6c0d797b5327f73be:18:2902
  1984
    - **Contraseña encontrada: 29021984 (29/02/1984)**



D. Arturo Ruiz Gasca

- Pista analizada: Combinación del nombre, apellidos e inserción estratégica del símbolo *.
- Técnica: Fuerza bruta directa mediante un script en Python implementado en Google Colab, que calcula y contrasta de manera automatizada los hashes SHA-256 (considerando las variantes de *salt* antes y después) frente a la combinación de permutações del nombre y apellidos.

Script de Generación (Python):

```
import hashlib
import itertools
```

```
target_hash =
"4baf587b8197529730b00a62be7f91278de1f8f52faca43c2d6baa4a1b70b7f5"
salt = "31"

def find_password():
    words_lists = [
        ["Arturo", "Ruiz", "Gasca"],
        ["arturo", "ruiz", "gasca"],
        ["ARTURO", "RUIZ", "GASCA"]
    ]

    for words in words_lists:
        for perm in itertools.permutations(words):
          base_combinations = [
              "".join(perm) + "*",
              "*" + "".join(perm),
              perm[0] + "*" + perm[1] + perm[2],
              perm[0] + perm[1] + "*" + perm[2],
              perm[0] + "*" + perm[1] + "*" + perm[2]
          ]

          for pwd in base_combinations:
              # Tenta o salt antes e depois para suprir a necessidade de número
              candidates = [
                  pwd + salt,
                  salt + pwd,
                  pwd + "31",
                  "31" + pwd
              ]
```

CONFIDENTIAL

```
            for candidate in candidates:
                h = hashlib.sha256(candidate.encode()).hexdigest()
                if h == target_hash:
                    return pwd, candidate

    return None, None
password, used_string = find_password()
if password:
    print(f"Senha encontrada! A senha é: {password}")
    print(f"String usada para o hash: {used_string}")
else:
    print("A senha ainda não foi encontrada. Precisamos tentar outras variações de hash ou codificação.")
```

- Comando ejecutado para el descifrado:

```
hashcat -m 1420 -a 0 hash_arturo.txt mega_wordlist_politica.txt
```

- Resultado del descifrado:

Dictionary cache built:

- Filename..: mega_wordlist.txt
- Passwords.: 3145729
- Bytes.....: 53280786
- Keyspace..: 3145729
- Runtime...: 0 secs

4baf587b8197529730b00a62be7f91278de1f8f52faca43c2d6baa4a1b70b7f5:31:ruiz*_arturo_*gasca

CONFIDENTIAL

```
┌──(kali㉿kali)-[~]
└─$ python3 bruteforce22.py --show
Testando arquivo: crackstation-human-only.txt
Testando arquivo: telnet-betterdefaultpasslist.txt
Testando arquivo: forenames-india-top1000.txt
Testando arquivo: malenames-usa-top1000.txt
Testando arquivo: names.txt
Testando arquivo: mssql-betterdefaultpasslist.txt
Testando arquivo: db2-betterdefaultpasslist.txt
Testando arquivo: ssh-betterdefaultpasslist.txt
Testando arquivo: ssh-password.txt
Testando arquivo: hash_arturo.txt
Testando arquivo: femalenames-usa-top1000.txt
Testando arquivo: mysql-betterdefaultpasslist.txt
Testando arquivo: postgres-betterdefaultpasslist.txt
Testando arquivo: snmp-default.txt
Testando arquivo: windows-betterdefaultpasslist.txt
Testando arquivo: mega_wordlist_politica.txt
Testando arquivo: ssh-user.txt
Testando arquivo: root-userpass.txt
Testando arquivo: oracle-betterdefaultpasslist.txt
Testando arquivo: gvit_subdomain_wordlist.txt
Testando arquivo: tomcat-betterdefaultpasslist.txt
Testando arquivo: dicionario-es.txt
Testando arquivo: palavras_arturo.txt
Testando arquivo: routers-userpass.txt
Testando arquivo: mega_wordlist.txt
Testando arquivo: ftp-betterdefaultpasslist.txt
Testando arquivo: familynames-usa-top1000.txt
Testando arquivo: vnc-betterdefaultpasslist.txt
```

```
Watchdog: Temperature abort trigger set to 90c

Host memory allocated for this attack: 512 MB (1942 MB free)

Dictionary cache built:
* Filename..: mega_wordlist.txt
* Passwords.: 3145729
* Bytes.....: 53280786
* Keyspace..: 3145729
* Runtime...: 0 secs

4baf587b8197529730b00a62be7f91278de1f8f52faca43c2d6baa4a1b70b7f5:31:ruiz*arturo*gasca

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 1410 (sha256($pass.$salt))
Hash.Target......: 4baf587b8197529730b00a62be7f91278de1f8f52faca43c2d6...7f5:31
Time.Started.....: Sun Sep 20 19:07:15 2026 (0 secs)
Time.Estimated...: Sun Sep 20 19:07:15 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.......: File (mega_wordlist.txt)
Guess.Queue......: 1/1 (100.00%)
Speed.#01........:  2417.3 kH/s (0.31ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered........: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.........: 3072/3145729 (0.10%)
Rejected.........: 0/3072 (0.00%)
Restore.Point....: 0/3145729 (0.00%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: arturoruizgasca → arturorUiZGASC*A
Hardware.Mon.#01.: Util: 21%

Started: Sun Sep 20 19:07:14 2026
Stopped: Sun Sep 20 19:07:16 2026
```

Lista de credenciales recuperadas

5. Luis Toreman Gerto
    - **Contraseña: procrastination**
    - Vector: Diccionario de palabras inglesas raras (mediante rockyou.txt).
6. Ana Pearse Sanz
    - **Contraseña: 12345678.22**
    - Vector: Ataque híbrido (Diccionario + Máscara de sufijo ?d?d).
7. Pedro Marteis Poncio
    - **Contraseña: 29021984**
    - Vector: Fuerza bruta con máscara numérica de 8 dígitos (fecha de nacimiento).
8. Arturo Ruiz Gasca
    - **Contraseña: ruiz*_arturo_*gasca**
    - Vector: Diccionario dirigido con permutación de nombre/apellidos e inserción de símbolos (*).

Herramientas y Programas Utilizados en el Pentest

1. Hashcat
    - Categoría: Descifrado de contraseñas / Cracking de hashes.
    - Uso: Herramienta principal para realizar los ataques de diccionario (-a 0), ataques híbridos (-a 6) y fuerza bruta con máscaras (-a 3) contra los hashes SHA-256 extraídos (modos 1410 y 1420).
2. Base64
    - Categoría: Descodificación / Manipulación de datos.
    - Uso: Utilizado en la terminal de Linux para descodificar las cadenas en Base64 extraídas de la base de datos (que contenían 44 caracteres correspondientes a 32 bytes de hash bruto).
3. Google Colab (Colaboratory)
    - Categoría: Entorno de Computación en la Nube / Notebooks de Python.

      Uso: Utilizado como entorno de ejecución en la nube para procesar los scripts en Python (como la generación de la mega_wordlist personalizada

CONFIDENTIAL

para el usuario Arturo) aprovechando recursos remotos sin saturar la máquina local.

4. Python (con la librería itertools)
    - Categoría: Automatización y Scripting / OSINT.
    - Uso: Utilizado para escribir y ejecutar el script personalizado que generó la mega_wordlist dirigida para el usuario Arturo, combinando permutaciones de nombres/apellidos, variaciones de mayúsculas/minúsculas e inserción algorítmica del símbolo *.
5. Rockyou.txt
    - Categoría: Wordlist / Diccionario de credenciales.
    - Uso: Base de datos de contraseñas comunes ampliamente utilizada en auditorías de seguridad para pruebas de diccionario y ataques híbridos.

TIEMPO DE CONCLUSIÓN DE LOS ANÁLISIS

A continuación se detalla el tiempo estimado y real de conclusión de las fases de análisis y descifrado durante la auditoría de seguridad:

1. Luis Toreman Gerto (Ataque de Diccionario puro)
    - Tiempo de conclusión: Menos de 1 minuto (rápido debido al uso de una palabra de diccionario estándar en la wordlist de alta frecuencia).
2. Ana Pearse Sanz (Ataque Híbrido - Diccionario + Máscara ?d?d)
    - Tiempo de conclusión: 24 segundos (registrado exactamente en las métricas de Hashcat: Time Started: 12:42:24 - Time Estimated: 12:42:48 a una velocidad promedio de ~4,715 kH/s).
3. Pedro Marteis Poncio (Fuerza Bruta con Máscara de 8 dígitos)
    - Tiempo de conclusión: Inferior a 5 minutos (espacio de claves acotado exclusivamente a patrones numéricos de fechas de nacimiento tipo DDMMAAAA / AAAAMMDD).
4. Arturo Ruiz Gasca (Diccionario OSINT personalizado vía Python / Google Colab)
    - Tiempo de conclusión: Aproximadamente de 2 a 3 minutos (incluyendo el tiempo de ejecución del script de generación en Google Colab y la posterior ejecución del ataque de diccionario dirigido en Hashcat).

CONFIDENTIAL

Tiempo Total Estimado del Pentest Técnico: Menos de 10 minutos para la recuperación completa de las 4 credenciales comprometidas, evidenciando la alta debilidad de los algoritmos de hashing rápidos (SHA-256 sin memory-hardness).

CONFIDENTIAL

Dictamen Final del Consultor

La organización opera bajo un falso sentido de seguridad al confiar exclusivamente en directrices estáticas de complejidad. La seguridad perimetral moderna exige asumir la brecha (*Assume Breach*) como premisa operativa. La implementación de las recomendaciones descritas no solo subsanará las vulnerabilidades detectadas en este informe de 8 horas de análisis técnico, sino que elevará la madurez de ciberseguridad corporativa hacia un modelo de defensa proactivo y resiliente.

Emitido por: Equipo Security Team X – Grupo 3

Fecha de Emisión: 20 de septiembre de 2026

Clasificación de Confidencialidad: *CONFIDENCIAL / RESTRICTED - Uso Exclusivo para la Alta Dirección y A-Level*

Estado del Proyecto: Auditoría de Credenciales y Análisis Forense Concluido (Duración total de ejecución técnica: 6 horas)

Aviso Legal y Descargo de Responsabilidad:

*Este documento contiene información técnica altamente sensible y confidencial sobre vulnerabilidades críticas que afectan directamente a la infraestructura tecnológica y al modelo de seguridad de la organización. Su divulgación, reproducción o distribución total o parcial sin la autorización expresa y por escrito de la dirección de seguridad está estrictamente prohibida. Las recomendaciones aquí contenidas deben ser tratadas como un plan de acción prioritario para mitigar el riesgo legal, operativo y reputacional de la entidad.XXXX